

8. Calidad de software y normativa

Este documento reúne las prácticas de calidad aplicadas en VentaGamer (organización del código, validaciones, seguridad, usabilidad y accesibilidad) y el análisis de cumplimiento de la **Ley 25.326 de Protección de Datos Personales** de la República Argentina.

8.1. Código modular y buenas prácticas

Organización del código

- **Backend en capas (Clean Architecture):** cuatro proyectos con dependencias unidireccionales — el dominio no conoce la base de datos ni el framework web. Cada capa tiene una única responsabilidad (ver [04 — Arquitectura](#)).
- **Frontend por funcionalidades:** cada dominio (auth, catálogo, carrito, admin, IA) agrupa su API, tipos y componentes; la infraestructura compartida (cliente HTTP, i18n) vive en `lib/` y los componentes visuales reutilizables en `components/ui/`.
- **Controllers delgados / servicios con la lógica:** los controllers reciben la solicitud, delegan en un servicio a través de su interfaz y traducen el resultado a HTTP. La lógica de negocio es testeable sin servidor web.
- **Contratos explícitos:** la comunicación entre capas usa interfaces (`IProductService` , `ICartService` , ...) y DTOs; las entidades del dominio nunca viajan directamente al cliente.

Herramientas de calidad

Práctica	Herramienta	Qué garantiza
Tipado estático en el frontend	TypeScript (modo estricto)	Errores de tipo detectados al compilar, no en ejecución.
Tipado estático en el backend	C# / .NET 8	Ídem, más <i>nullability</i> verificada por el compilador.
Análisis de estilo	ESLint (+ plugins de React)	Estilo homogéneo y detección de patrones problemáticos.
Convenciones de nombres	Consistentes en todo el código	Entidades y servicios en inglés técnico; interfaz de usuario en español.
Versionado	Git	Historia de cambios revisable; el esquema de BD versionado como migraciones.

Principios de diseño aplicados

- **Separación de intereses:** presentación, lógica y datos en capas distintas.

- **Inversión de dependencias:** las capas internas definen interfaces; las externas las implementan.
- **No repetición (DRY):** la auditoría se implementa una sola vez como interceptor (no en cada servicio); el cliente HTTP y el manejo de errores del frontend están centralizados.
- **Inmutabilidad donde importa:** los ítems de un pedido son instantáneas (snapshot) que no cambian aunque cambie el catálogo.
- **Fallar de forma controlada:** excepciones de dominio específicas (`UserBlockedException` , stock insuficiente) traducidas a códigos HTTP claros.

8.2. Validaciones

La regla general del sistema es: **el cliente valida para ayudar al usuario; el servidor valida para proteger los datos**. Ninguna validación existe solo en el navegador.

Validación	Cliente (React)	Servidor (ASP.NET Core)
Campos obligatorios y formatos	Formularios con mensajes inmediatos	Modelos de request validados
Contraseña mínima (8 caracteres)	Registro, con indicador de fortaleza	Rechazo en <code>AuthService</code>
Usuario duplicado	—	HTTP 409 con verificación en BD
Stock disponible	Deshabilita botones sin stock	Verificación en carrito y otra vez dentro de la transacción de checkout
Cantidades positivas	Controles +/- acotados	Restricciones en la entidad y en BD (<code>CHECK</code>)
Permisos	Ocultar opciones sin permiso	Políticas de autorización en cada endpoint
URL de configuración IA	Validación de formato	<code>Uri.TryCreate</code> antes de persistir

8.3. Seguridad

Mecanismo	Implementación	Contra qué protege
Hash de contraseñas PBKDF2	Hasher de ASP.NET Identity con salt individual; nunca se almacena texto plano.	Robo de credenciales ante una filtración de la BD.
Tokens JWT firmados	HMAC-SHA256, vigencia 60 minutos, validación de emisor/audiencia/vencimiento.	Suplantación de identidad y manipulación del token.
Bloqueo de cuenta	3 intentos fallidos consecutivos → cuenta bloqueada (HTTP 423); desbloqueo solo por administrador.	Adivinación de contraseñas dirigida a una cuenta.
Rate limiting	60 solicitudes/min por IP global; 5/min en login y registro; 10 mensajes/min en el chat IA.	Fuerza bruta y abuso del servicio.
Autorización granular	12 permisos verificados por políticas en el servidor, en cada solicitud.	Escalamiento de privilegios manipulando la interfaz.
Consultas parametrizadas	Todo el acceso a datos pasa por EF Core (LINQ → SQL parametrizado).	Inyección SQL.
Protección XSS	React escapa por defecto todo el contenido interpolado.	Inyección de scripts en la interfaz.
CORS restringido	Solo los orígenes del frontend configurados pueden llamar a la API desde el navegador.	Solicitudes desde sitios no autorizados.
Transacciones	El checkout es atómico: o se completa todo o no se hace nada.	Estados inconsistentes (stock descontado sin pedido).
Auditoría automática	Interceptor de EF Core registra todo cambio en entidades sensibles, con usuario y fecha.	Operaciones sin rastro; facilita el análisis posterior de incidentes.
Configuración fuera del código	Claves (JWT, contraseña de BD) inyectadas por variables de entorno (<code>.env</code>).	Exposición de secretos en el repositorio.

8.4. Usabilidad

- **Retroalimentación inmediata:** indicadores de carga (spinners), avisos de éxito (toasts), mensajes de error específicos y en lenguaje claro.
- **Estados vacíos cuidados:** cuando no hay resultados, carrito vacío o faltan permisos, se muestra una pantalla explicativa con la acción sugerida, nunca un espacio en blanco.
- **Prevención de errores:** botones deshabilitados cuando la acción no es válida (sin stock, formulario incompleto, asistente fuera de línea).

- **Consistencia:** todas las pantallas usan la misma biblioteca de componentes, por lo que botones, tablas y formularios se ven y comportan igual en todo el sistema.
- **Navegación clara:** menú según permisos (el usuario no ve opciones que no puede usar), página 404 propia, ayuda con preguntas frecuentes.
- **Usuarios demo:** la pantalla de login ofrece credenciales de demostración por rol, facilitando la evaluación del sistema.

8.5. Accesibilidad

Implementado:

- Idioma del documento declarado (`lang="es"`).
- `aria-label` en botones de solo ícono (ampliar imagen, +/- del carrito, cerrar modal, menú móvil).
- Cierre de modales y visor de imágenes con la tecla **Escape**; bloqueo del scroll de fondo.
- `aria-pressed` en conmutadores; `aria-hidden` en elementos decorativos.
- Contraste alto por diseño (texto claro sobre fondo oscuro).

Limitaciones conocidas (mejoras futuras): no hay enlaces de salto ("saltar al contenido"), el foco no queda atrapado dentro de los modales abiertos, algunas animaciones intensas no respetan aún la preferencia de "reducir movimiento" del sistema, y la navegación completa por teclado no está verificada en todas las pantallas. Se documentan explícitamente como parte del análisis de calidad.

8.6. Ley 25.326 — Protección de Datos Personales

La **Ley 25.326** regula el tratamiento de datos personales en la Argentina: exige que los datos se recolecten con un fin determinado y consentimiento del titular (arts. 4-6), que se garantice su **seguridad y confidencialidad** (arts. 9-10), y que el titular pueda ejercer los derechos de **acceso, rectificación y supresión** (arts. 14-16).

Datos personales que trata el sistema

VentaGamer aplica el principio de **minimización**: recolecta únicamente los datos indispensables.

Dato	Finalidad	Base de licitud
Nombre de usuario	Identificación de la cuenta	Consentimiento al registrarse
Contraseña (solo hash PBKDF2)	Autenticación	Consentimiento al registrarse
Idioma preferido	Personalización de la interfaz	Consentimiento al registrarse
Historial de compras	Gestión de pedidos y comprobantes	Ejecución de la relación de consumo
Fecha de último acceso e intentos fallidos	Seguridad de la cuenta	Interés legítimo (seguridad)
Conversaciones con el asistente IA	Continuidad de la conversación	Consentimiento (uso voluntario del asistente)

Cabe destacar que el sistema **no** recolecta datos sensibles (art. 7): no se piden nombre real, dirección, teléfono ni datos financieros (no hay pasarela de pagos en esta versión).

Cómo cumple el sistema cada exigencia

Exigencia de la ley	Implementación en VentaGamer
Consentimiento informado (arts. 5-6)	El formulario de registro exige aceptar los términos y el aviso de privacidad antes de crear la cuenta.
Calidad y finalidad de los datos (art. 4)	Solo se piden los datos necesarios para operar; no se usan con fines distintos ni se ceden a terceros.
Seguridad de los datos (art. 9)	Contraseñas con hash, autenticación JWT, autorización granular, rate limiting, CORS restringido y transacciones (detallado en 8.3).
Deber de confidencialidad (art. 10)	Acceso a datos de otros usuarios restringido a perfiles administrativos con permisos específicos; toda consulta administrativa queda auditada.
Derecho de acceso (art. 14)	El usuario puede consultar sus datos (perfil, pedidos, conversaciones) desde su sesión.
Derecho de rectificación y supresión (art. 16)	El usuario puede eliminar sus conversaciones con el asistente; la administración puede corregir o dar de baja cuentas. La bitácora conserva los eventos de forma disociada (si se elimina el usuario, sus registros de auditoría quedan sin referencia personal — <code>SET NULL</code>).
Procesamiento local de IA	Las consultas al asistente se procesan en un servidor propio (Ollama, local): los datos de los usuarios no se envían a servicios de IA de terceros.

Aviso de privacidad

El sistema incluye la aceptación de términos en el registro. El siguiente texto modelo de **aviso de privacidad** acompaña al sistema y resume la política de tratamiento de datos:

Aviso de privacidad — VentaGamer. En cumplimiento de la Ley 25.326 de Protección de Datos Personales, se informa que los datos recabados al registrarse (nombre de usuario, contraseña e idioma preferido) y los generados por el uso del sistema (historial de compras y conversaciones con el asistente virtual) serán utilizados exclusivamente para operar la plataforma: autenticar su cuenta, gestionar sus compras y personalizar su experiencia. Las contraseñas se almacenan cifradas de forma irreversible y ningún dato se cede a terceros. Usted puede ejercer en todo momento sus derechos de acceso, rectificación y supresión de datos contactando al administrador del sistema. El titular de los datos podrá, asimismo, presentar reclamos ante la Agencia de Acceso a la Información Pública, órgano de control de la Ley 25.326.

8.7. Trazabilidad: la bitácora como mecanismo de control

La bitácora de auditoría (ver CU-08 en 03 — Casos de uso) es también un instrumento de cumplimiento: permite demostrar **quién** realizó cada operación sobre los datos y **cuándo**. Al implementarse como interceptor a nivel del acceso a datos, ninguna modificación de productos, usuarios, roles o pedidos puede eludir el registro, lo que respalda tanto la seguridad interna como la rendición de cuentas exigible a un responsable de base de datos según la normativa.